

**SWT 22022 – Practical for
Internet Application
Development**

Department of Information
and Communication
Technology
Faculty of Technology



**Lab sheet :10
Reg. Number: SEU/IS/20/ICT/084
Academic Year :2020/2021
Date: 2024.07.15
Practical No :10**

Title: Web Security in PHP and JavaScript

Aims:

- **Implement security measures in PHP and JavaScript**

Tasks:

- **Identify common security threats**
- **Implement PHP security practices**
- **Implement JavaScript security practices**

Activities :

1. Identify the common security threats

I. SQL Injection

- SQL Injection is a type of attack where an attacker can execute arbitrary SQL code on a database by manipulating user input.
- This can lead to unauthorized access to data, modification of data, and even deletion of the database.

II. Cross-Site Scripting (XSS)

- XSS is an attack where an attacker injects malicious scripts into content from otherwise trusted websites.
- This leads to data theft, session hijacking, and other malicious actions.

III. Cross-Site Request (CSRF)

- CSRF is an attack that tricks the user into submitting a malicious request.
- It exploits the trust a web application has in the authenticated user.

IV. Remote Code Execution (RCE)

- RCE allows an attacker to execute arbitrary code on the server, often leading to complete server compromise.

2. Implement PHP security practices

I. Input validation and sanitization

```
$username = filter_var($data->username, FILTER_SANITIZE_STRING);  
$password = filter_var($data->password, FILTER_SANITIZE_STRING);  
$user->setUsername($username);
```

```
$user->setPassword($password);
```

II. SQL injection prevention

```
public function create() {  
    $query = "INSERT INTO `expenses` (`description`, `amount`) VALUES (?, ?)";  
    $stmt = $this->connection->prepare($query);  
    if ($stmt === false) {  
        return false;  
    }  
    $stmt->bind_param('sd', $this->description, $this->amount);  
    $result = $stmt->execute();  
    $stmt->close();  
    return $result;  
}
```

III. XSS prevention

```
$username = htmlspecialchars($data->username, ENT_QUOTES, 'UTF-8');  
$password = htmlspecialchars($data->password, ENT_QUOTES, 'UTF-8');  
$email = htmlspecialchars($data->email, ENT_QUOTES, 'UTF-8');  
$user->setUsername($username);  
$user->setPassword($password);  
$user->setEmail($email);
```

IV. Session management

```
<?php  
$cookieParams = [  
    'lifetime' => 0,  
    'path' => '/',  
    'domain' => '',  
    'secure' => true,  
    'httponly' => true,  
    'samesite' => 'Strict'  
];  
session_set_cookie_params($cookieParams);  
session_start();  
  
require_once '../database/User.php';  
$database = new Database("localhost", "root", "", "expense_tracker");  
$db = $database->getConnection();  
  
$user = new User($db);  
  
// Assuming you are receiving JSON input  
$data = json_decode(file_get_contents("php://input"));
```

```
// Sanitize input for extra safety
$username = htmlspecialchars(trim($data->username ?? ''), ENT_QUOTES, 'UTF-8');
$password = htmlspecialchars(trim($data->password ?? ''), ENT_QUOTES, 'UTF-8');

$user->setUsername($username);
$user->setPassword($password);

if ($user->login()) {
    session_regenerate_id(true);
    $_SESSION['username'] = $user->username;
    echo json_encode(["message" => "Login successful."]);
} else {
    echo json_encode(["message" => "Login failed."]);
}
?>
```

3. Implement JavaScript security practices I. Avoid inline JavaScript
 - II. Content Security Policy (CSP)

```
<head>
  <title>User Authentication</title>
  <meta http-equiv="Content-Security-Policy" content="default-src 'self'; script-
src 'self'; style-src 'self'; img-src 'self';">
  <link rel="stylesheet" type="text/css" href="style.css">
</head>
```

III. DOM manipulation

```
async function register() {

  // Get form values
  const username = document.getElementById('registerUsername').value;
  const password = document.getElementById('registerPassword').value;
  const email = document.getElementById('registerEmail').value;

  // Client-side validation
  if (!username || !password || !email) {
    alert('All fields are required.');
```

```
    return;
  }

  const emailPattern = /^[a-zA-Z0-9._-]+@[a-zA-Z0-9.-]+\.[a-zA-Z]{2,6}$/;
  if (!emailPattern.test(email)) {
```

```

        alert('Please enter a valid email address.');
```

}

```

    if (password.length < 8) {
        alert('Password must be at least 8 characters long.');
```

}

```

    try {
        const response = await fetch('php/register.php', {
            method: 'POST',
            body: JSON.stringify({ username, password, email }),
            headers: { 'Content-Type': 'application/json' }
        });

        if (!response.ok) {
            throw new Error('Network response was not ok');
        }

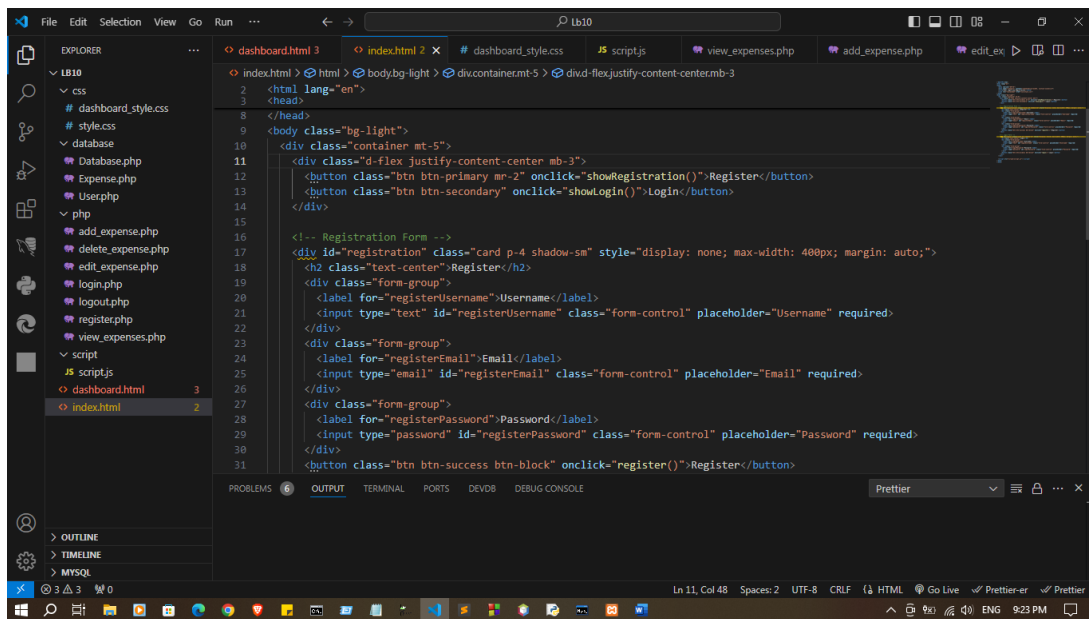
        const result = await response.json();

        if (result.success) {
            showLoginForm();
            alert('Registration successful. Please login.');
```

} else {

```

            alert('Registration failed: ' + result.message);
        }
    } catch (error) {
        alert('Error registering user: ' + error.message);
    }
}
```



Index.html

```
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>User Login and Registration</title>
  <link rel="stylesheet" href="css/style.css">
</head>
<body class="bg-light">
  <div class="container mt-5">
    <div class="d-flex justify-content-center mb-3">
      <button class="btn btn-primary mr-2" onclick="showRegistration()">Register</button>
      <button class="btn btn-secondary" onclick="showLogin()">Login</button>
    </div>

    <!-- Registration Form -->
    <div id="registration" class="card p-4 shadow-sm" style="display: none; max-width: 400px; margin: auto;">
      <h2 class="text-center">Register</h2>
      <div class="form-group">
        <label for="registerUsername">Username</label>
        <input type="text" id="registerUsername" class="form-control" placeholder="Username"
required>
      </div>
      <div class="form-group">
        <label for="registerEmail">Email</label>
```

```

        <input type="email" id="registerEmail" class="form-control" placeholder="Email"
required>
    </div>
    <div class="form-group">
        <label for="registerPassword">Password</label>
        <input type="password" id="registerPassword" class="form-control"
placeholder="Password" required>
    </div>
    <button class="btn btn-success btn-block" onclick="register()">Register</button>
</div>

<!-- Login Form -->
<div id="login" class="card p-4 shadow-sm" style="display: block; max-width: 400px;
margin: auto;">
    <h2 class="text-center">Login</h2>
    <div class="form-group">
        <label for="loginUsername">Username</label>
        <input type="text" id="loginUsername" class="form-control" placeholder="Username"
required>
    </div>
    <div class="form-group">
        <label for="loginPassword">Password</label>
        <input type="password" id="loginPassword" class="form-control" placeholder="Password"
required>
    </div>
    <button class="btn btn-primary btn-block" onclick="login()">Login</button>
</div>

<script src="script/script.js"></script>
</body>
</html>

```

dashboard.html

```

<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Dashboard</title>
    <link rel="stylesheet" href="css/dashboard_style.css">
</head>
<body>
    <div class="container">
        <h1>Welcome to the Dashboard</h1>
        <button onclick="logout()">Logout</button>
    </div>

```

```

<h2>Add New Expense</h2>
<form id="addExpenseForm" onsubmit="addExpense(event)">
  <label>Description</label>
  <input type="text" id="description" required>
  <label>Amount</label>
  <input type="number" id="amount" required>
  <button type="submit">Add Expense</button>
</form>

<h2>Expense List</h2>
<table id="expenseTable">
  <thead>
    <tr>
      <th>Description</th>
      <th>Amount</th>
      <th>Actions</th>
    </tr>
  </thead>
  <tbody id="expenseTableBody">
  </tbody>
</table>

<div id="editForm" style="display:none;">
  <h2>Edit Expense</h2>
  <form onsubmit="updateExpense(event)">
    <input type="hidden" id="expenseId">
    <label>Description</label>
    <input type="text" id="editDescription" required>
    <label>Amount</label>
    <input type="number" id="editAmount" required>
    <button type="submit">Update</button>
    <button type="button"
onclick="document.getElementById('editForm').style.display='none'">Cancel</button>
  </form>
</div>
</div>

<script src="script/script.js"></script>
</body>
</html>

```

Script/script.js

```

document.addEventListener('DOMContentLoaded', () => {
  loadExpenses();
  displayData();
});

```



```

document.addEventListener('DOMContentLoaded', loadExpenses);

async function logout() {
  const response = await fetch('php/logout.php', { method: 'POST' });
  const result = await response.json();
  if (result.message === "Logout success!") {
    window.location.href = "index.html";
  } else {
    alert("Logout failed");
  }
}

async function loadExpenses() {
  const response = await fetch('php/view_expenses.php');
  const data = await response.json();
  const expenseTableBody = document.getElementById('expenseTableBody');
  expenseTableBody.innerHTML = '';

  data.records.forEach(expense => {
    const row = document.createElement('tr');
    row.innerHTML = `
      <td>${expense.description}</td>
      <td>${expense.amount}</td>
      <td>
        <button onclick="showEditForm(${expense.id}, '${expense.description}',
${expense.amount})">Edit</button>
        <button onclick="deleteExpense(${expense.id})">Delete</button>
      </td>
    `;
    expenseTableBody.appendChild(row);
  });
}

async function addExpense(event) {
  event.preventDefault();
  const description = document.getElementById('description').value;
  const amount = document.getElementById('amount').value;
  const response = await fetch('php/add_expense.php', {
    method: 'POST',
    headers: { 'Content-Type': 'application/json' },
    body: JSON.stringify({ description, amount })
  });
  const result = await response.json();
  if (result.message === "Expense added.") {
    loadExpenses();
    document.getElementById('addExpenseForm').reset();
  } else {
    alert("Failed to add expense");
  }
}

```

```

    }
  }

  async function showEditForm(id, description, amount) {
    document.getElementById('expenseId').value = id;
    document.getElementById('editDescription').value = description;
    document.getElementById('editAmount').value = amount;
    document.getElementById('editForm').style.display = 'block';
  }

  async function updateExpense(event) {
    event.preventDefault();
    const id = document.getElementById('expenseId').value;
    const description = document.getElementById('editDescription').value;
    const amount = document.getElementById('editAmount').value;
    const response = await fetch('php/edit_expense.php', {
      method: 'POST',
      headers: { 'Content-Type': 'application/json' },
      body: JSON.stringify({ id, description, amount })
    });
    const result = await response.json();
    if (result.message === "Expense updated.") {
      loadExpenses();
      document.getElementById('editForm').style.display = 'none';
    } else {
      alert("Failed to update expense");
    }
  }

  async function deleteExpense(id) {
    if (confirm("Are you sure you want to delete this expense?")) {
      const response = await fetch('php/delete_expense.php', {
        method: 'POST',
        headers: { 'Content-Type': 'application/json' },
        body: JSON.stringify({ id })
      });
      const result = await response.json();
      if (result.message === "Expense deleted.") {
        loadExpenses();
      } else {
        alert("Failed to delete expense");
      }
    }
  }

  function showEditForm(id, description, amount) {
    document.getElementById('expenseId').value = id;

```

```

document.getElementById('editDescription').value = description;
document.getElementById('editAmount').value = amount;
document.getElementById('editForm').style.display = 'block';
}

function validateForm(form) {
  const inputs = form.elementsByTagName('input');
  let isValid = true;

  Array.from(inputs).forEach(input => {
    if (input.hasAttribute('required') && !input.value.trim()) {
      input.classList.add('is-invalid');
      isValid = false;
    } else {
      input.classList.remove('is-invalid');
    }
  });

  return isValid;
}

// Show registration form
function showRegistration() {
  document.getElementById('registration').style.display = 'block';
  document.getElementById('login').style.display = 'none';
}

// Show login form
function showLogin() {
  document.getElementById('login').style.display = 'block';
  document.getElementById('registration').style.display = 'none';
}

// Register new user
async function register() {
  const username = document.getElementById('registerUsername').value.trim();
  const email = document.getElementById('registerEmail').value.trim();
  const password = document.getElementById('registerPassword').value.trim();

  if (username && email && password) {
    try {
      const response = await fetch('php/register.php', {
        method: 'POST',
        headers: { 'Content-Type': 'application/json' },
        body: JSON.stringify({ username, email, password })
      });
    }
  }
}

```

```

        const result = await response.json();
        alert(result.message);
        if (result.message === "User was registered.") showLogin();
    } catch (error) {
        console.error('Registration error:', error);
    }
} else {
    alert("Please fill in all fields.");
}
}

// Login user
async function login() {
    const username = document.getElementById('loginUsername').value.trim();
    const password = document.getElementById('loginPassword').value.trim();

    if (username && password) {
        try {
            const response = await fetch('php/login.php', {
                method: 'POST',
                headers: { 'Content-Type': 'application/json' },
                body: JSON.stringify({ username, password })
            });
            const result = await response.json();
            if (result.message === "Login success") {
                window.location.href = "dashboard.html"; // Redirect to dashboard
            } else {
                alert("Login failed. Check your username and password.");
            }
        } catch (error) {
            console.error('Login error:', error);
        }
    } else {
        alert("Please enter both username and password.");
    }
}
}

```

Database/
Database.php

```

<?php
class Database {
    private $host;
    private $username;
    private $password;
    private $database;
    private $connection;

    public function __construct($host, $username, $password, $database) {

```

```

        $this->host = $host;
        $this->username = $username;
        $this->password = $password;
        $this->database = $database;
        $this->connect();
    }

    private function connect() {
        $this->connection = mysqli_connect($this->host, $this->username, $this->password,
$this->database);

        if (mysqli_connect_errno()) {
            die("Database connection failed: " . mysqli_connect_error());
        }
    }

    public function getConnection() {
        return $this->connection;
    }
}
?>

```

Expense.php

```

<?php
class Expense {
    private $connection;
    private $amount;
    private $description;
    private $id;

    public function __construct($connection) {
        $this->connection = $connection;
    }

    public function setAmount($amount) {
        $this->amount = $amount;
    }

    public function setDescription($description) {
        $this->description = $description;
    }

    public function setId($id) {
        $this->id = $id;
    }

    public function getAllExpenses() {

```

```

$query = "SELECT * FROM expenses";
$result = mysqli_query($this->connection, $query);

if (!$result) {
    die("Failed to retrieve data: " . mysqli_error($this->connection));
}

$expenses = [];
while ($row = mysqli_fetch_assoc($result)) {
    $expenses[] = $row;
}
return $expenses;
}

public function create() {
    $query = "INSERT INTO `expenses` (`description`, `amount`) VALUES (?, ?)";
    $stmt = $this->connection->prepare($query);
    if ($stmt === false) {
        return false;
    }
    $stmt->bind_param('sd', $this->description, $this->amount);
    $result = $stmt->execute();
    $stmt->close();
    return $result;
}

public function delete() {
    $query = "DELETE FROM expenses WHERE id = ?";
    $stmt = $this->connection->prepare($query);
    if ($stmt === false) {
        return false;
    }
    $stmt->bind_param('i', $this->id);
    $result = $stmt->execute();
    $stmt->close();
    return $result;
}

public function update() {
    $query = "UPDATE expenses SET amount = ?, description = ? WHERE id = ?";
    $stmt = $this->connection->prepare($query);
    if ($stmt === false) {
        return false;
    }
    $stmt->bind_param('dsi', $this->amount, $this->description, $this->id);
    $result = $stmt->execute();
    $stmt->close();
}

```

```

        return $result;
    }
}
?>

```

User.php

```

<?php
class User {
    private $conn;
    public $username;
    public $password;
    public $email;

    public function __construct($db) {
        $this->conn = $db;
    }

    public function setUsername($username) {
        $this->username = $username;
    }

    public function setPassword($password) {
        $this->password = $password;
    }

    public function setEmail($email) {
        $this->email = $email;
    }

    public function register() {
        $hash_password = password_hash($this->password, PASSWORD_DEFAULT);
        $query = "INSERT INTO users (username, password, email) VALUES (?, ?, ?)";
        $stmt = mysqli_prepare($this->conn, $query);
        mysqli_stmt_bind_param($stmt, "sss", $this->username, $hash_password, $this->email);
        $result = mysqli_stmt_execute($stmt);
        mysqli_stmt_close($stmt);
        return $result;
    }

    public function login() {
        $query = "SELECT id, username, password FROM users WHERE username = ? LIMIT 1";
        $stmt = mysqli_prepare($this->conn, $query);
        mysqli_stmt_bind_param($stmt, "s", $this->username);
        mysqli_stmt_execute($stmt);
        $result = mysqli_stmt_get_result($stmt);
    }
}

```

```

        if ($row = mysqli_fetch_assoc($result)) {
            if (password_verify($this->password, $row['password'])) {
                return true;
            }
        }
        mysqli_stmt_close($stmt);
        return false;
    }
}
?>

```

add_expense.php

```

<?php
require_once '../database/Expense.php';
require_once '../database/Database.php';

$databse = new Database("localhost", "root", "", "expense_tracker");
$db = $databse->getConnection();
$expense = new Expense($db);

$data = json_decode(file_get_contents("php://input"), true);
$expense->setDescription($data['description']);
$expense->setAmount($data['amount']);

header('Content-Type: application/json');
echo json_encode(["message" => $expense->create() ? "Expense added." : "Failed to add expense"]);
?>

```

delete_expense.php

```

<?php
require_once '../database/Expense.php';
require_once '../database/Database.php';

$databse = new Database("localhost", "root", "", "expense_tracker");
$db = $databse->getConnection();
$expense = new Expense($db);

$data = json_decode(file_get_contents("php://input"), true);
$expense->setDescription($data['description']);
$expense->setAmount($data['amount']);

header('Content-Type: application/json');
echo json_encode(["message" => $expense->create() ? "Expense added." : "Failed to add expense"]);
?>

```


edit_expense.php

```
<?php
require_once '../database/Expense.php';
require_once '../database/Database.php';

$database = new Database("localhost", "root", "", "expense_tracker");
$db = $database->getConnection();
$expense = new Expense($db);

$data = json_decode(file_get_contents("php://input"), true);
$expense->setId($data['id']);
$expense->setDescription($data['description']);
$expense->setAmount($data['amount']);

header('Content-Type: application/json');
echo json_encode(["message" => $expense->update() ? "Expense updated." : "Failed to
update expense"]);
?>
```

login.php

```
<?php
session_start();
require_once '../database/Database.php';
require_once '../database/User.php';

$database = new Database("localhost", "root", "", "expense_tracker");
$db_connection = $database->getConnection();
$user = new User($db_connection);

$data = json_decode(file_get_contents("php://input"));
$username = filter_var($data->username, FILTER_SANITIZE_STRING);
$password = filter_var($data->password, FILTER_SANITIZE_STRING);

$user->setUsername($username);
$user->setPassword($password);

header('Content-Type: application/json');
if ($user->login()) {
    $_SESSION['username'] = $user->username;
    echo json_encode(["message" => "Login success"]);
} else {
    echo json_encode(["message" => "Login failed"]);
}
?>
```

logout.php

```
<?php
session_start();
session_destroy();
header('Content-Type: application/json');
echo json_encode(["message" => "Logout success!"]);
?>
```

register.php

```
<?php
session_start();
require_once '../database/Database.php';
require_once '../database/User.php';

$databse = new Database("localhost", "root", "", "expense_tracker");
$db = $databse->getConnection();
$user = new User($db);

$data = json_decode(file_get_contents("php://input"));
$username = htmlspecialchars($data->username, ENT_QUOTES, 'UTF-8');
$password = htmlspecialchars($data->password, ENT_QUOTES, 'UTF-8');
$email = htmlspecialchars($data->email, ENT_QUOTES, 'UTF-8');

$user->setUsername($username);
$user->setPassword($password);
$user->setEmail($email);

header('Content-Type: application/json');
if ($user->register()) {
    echo json_encode(["message" => "User was registered."]);
} else {
    echo json_encode(["message" => "Unable to register the user."]);
}
?>
```

view_expenses.php

```
<?php
require_once '../database/Expense.php';
require_once '../database/Database.php';

$databse = new Database("localhost", "root", "", "expense_tracker");
$db = $databse->getConnection();
$expense = new Expense($db);

header('Content-Type: application/json');
echo json_encode(["records" => $expense->getAllExpenses()]);
?>
```

```
document.addEventListener('DOMContentLoaded', () => {
  loadExpenses();
  displayData();
});

document.addEventListener('DOMContentLoaded', loadExpenses);

async function logout() {
  const response = await fetch('php/logout.php', { method: 'POST' });
  const result = await response.json();
  if (result.message === "Logout success!") {
    window.location.href = "index.html";
  } else {
    alert("Logout failed");
  }
}

async function loadExpenses() {
  const response = await fetch('php/view_expenses.php');
  const data = await response.json();
  const expenseTableBody = document.getElementById('expenseTableBody');
  expenseTableBody.innerHTML = '';

  data.records.forEach(expense => {
    const row = document.createElement('tr');
    row.innerHTML = `
      <td>${expense.description}</td>
      <td>${expense.amount}</td>
      <td>
        <button onclick="showEditForm(${expense.id}, '${expense.description}',
${expense.amount})">Edit</button>
        <button onclick="deleteExpense(${expense.id})">Delete</button>
      </td>
    `;
    expenseTableBody.appendChild(row);
  });
}

async function addExpense(event) {
  event.preventDefault();
  const description = document.getElementById('description').value;
  const amount = document.getElementById('amount').value;
  const response = await fetch('php/add_expense.php', {
    method: 'POST',
    headers: { 'Content-Type': 'application/json' },
    body: JSON.stringify({ description, amount })
  });
}
```

```

    });
    const result = await response.json();
    if (result.message === "Expense added.") {
        loadExpenses();
        document.getElementById('addExpenseForm').reset();
    } else {
        alert("Failed to add expense");
    }
}

async function showEditForm(id, description, amount) {
    document.getElementById('expenseId').value = id;
    document.getElementById('editDescription').value = description;
    document.getElementById('editAmount').value = amount;
    document.getElementById('editForm').style.display = 'block';
}

async function updateExpense(event) {
    event.preventDefault();
    const id = document.getElementById('expenseId').value;
    const description = document.getElementById('editDescription').value;
    const amount = document.getElementById('editAmount').value;
    const response = await fetch('php/edit_expense.php', {
        method: 'POST',
        headers: { 'Content-Type': 'application/json' },
        body: JSON.stringify({ id, description, amount })
    });
    const result = await response.json();
    if (result.message === "Expense updated.") {
        loadExpenses();
        document.getElementById('editForm').style.display = 'none';
    } else {
        alert("Failed to update expense");
    }
}

async function deleteExpense(id) {
    if (confirm("Are you sure you want to delete this expense?")) {
        const response = await fetch('php/delete_expense.php', {
            method: 'POST',
            headers: { 'Content-Type': 'application/json' },
            body: JSON.stringify({ id })
        });
        const result = await response.json();
        if (result.message === "Expense deleted.") {
            loadExpenses();
        } else {
            alert("Failed to delete expense");
        }
    }
}

```

```

    }
  }
}

function showEditForm(id, description, amount) {
  document.getElementById('expenseId').value = id;
  document.getElementById('editDescription').value = description;
  document.getElementById('editAmount').value = amount;
  document.getElementById('editForm').style.display = 'block';
}

function validateForm(form) {
  const inputs = form.getElementsByTagName('input');
  let isValid = true;

  Array.from(inputs).forEach(input => {
    if (input.hasAttribute('required') && !input.value.trim()) {
      input.classList.add('is-invalid');
      isValid = false;
    } else {
      input.classList.remove('is-invalid');
    }
  });

  return isValid;
}

// Show registration form
function showRegistration() {
  document.getElementById('registration').style.display = 'block';
  document.getElementById('login').style.display = 'none';
}

// Show login form
function showLogin() {
  document.getElementById('login').style.display = 'block';
  document.getElementById('registration').style.display = 'none';
}

// Register new user
async function register() {
  const username = document.getElementById('registerUsername').value.trim();
  const email = document.getElementById('registerEmail').value.trim();
  const password = document.getElementById('registerPassword').value.trim();

  if (username && email && password) {

```

```

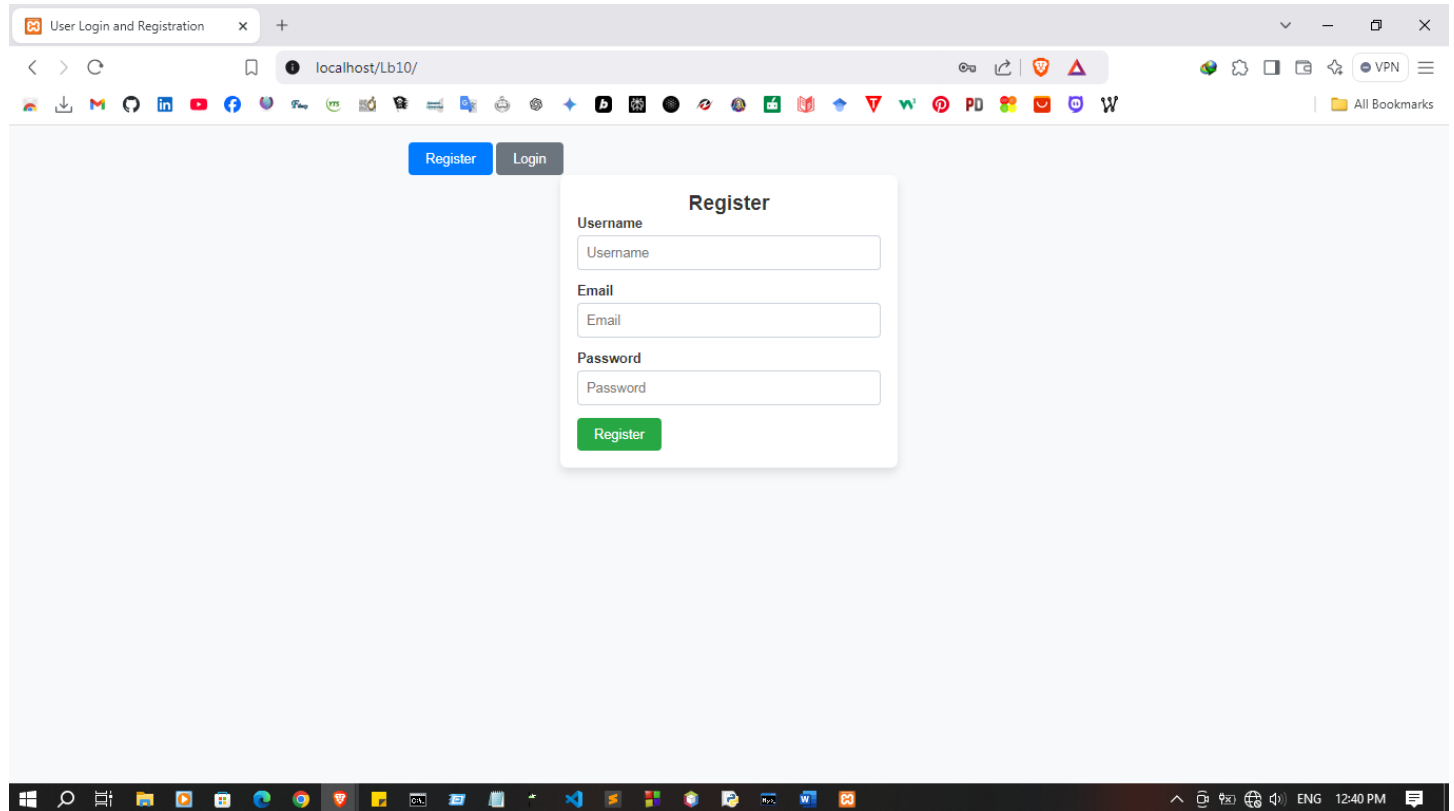
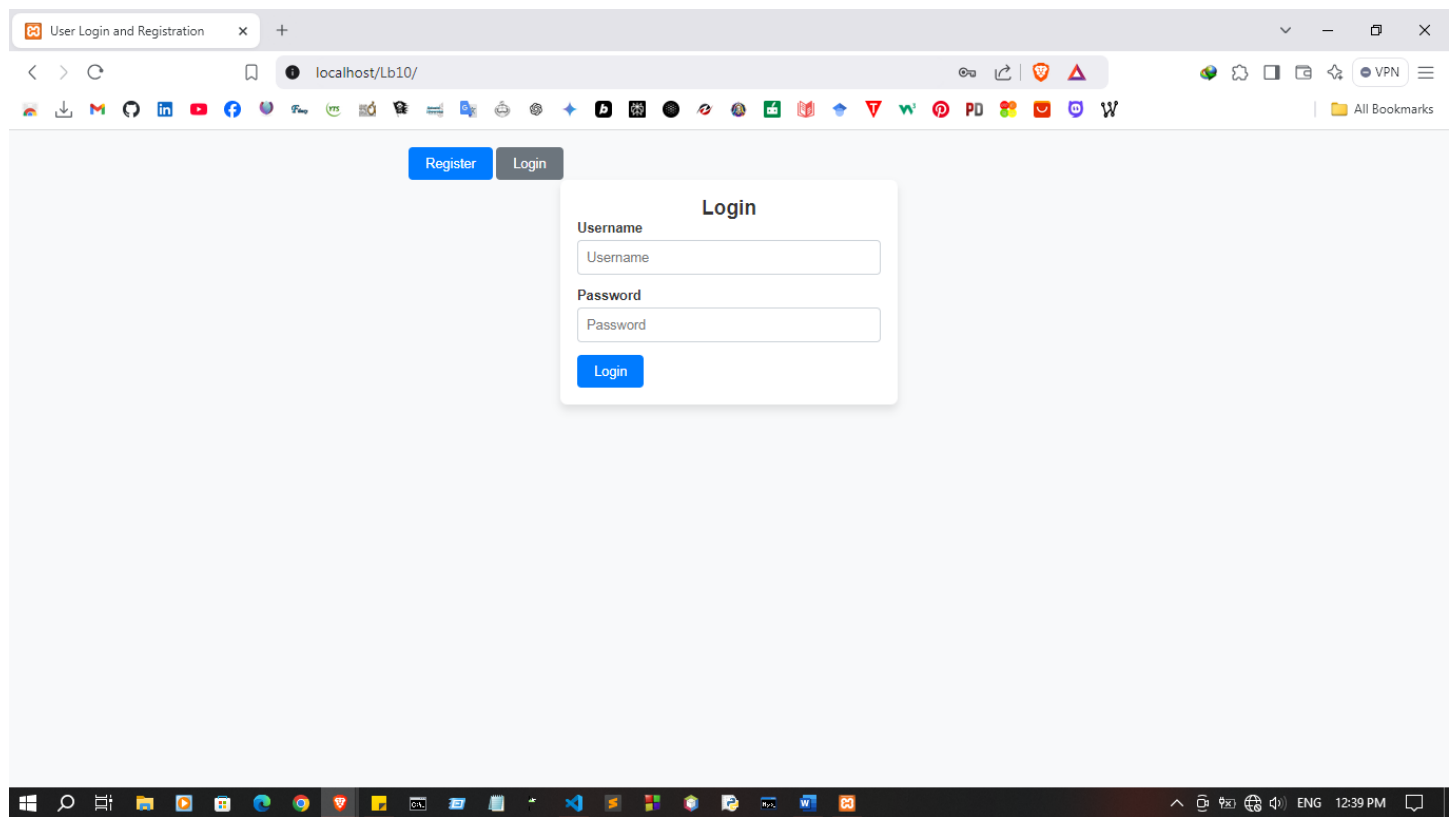
    try {
        const response = await fetch('php/register.php', {
            method: 'POST',
            headers: { 'Content-Type': 'application/json' },
            body: JSON.stringify({ username, email, password })
        });
        const result = await response.json();
        alert(result.message);
        if (result.message === "User was registered.") showLogin();
    } catch (error) {
        console.error('Registration error:', error);
    }
} else {
    alert("Please fill in all fields.");
}
}

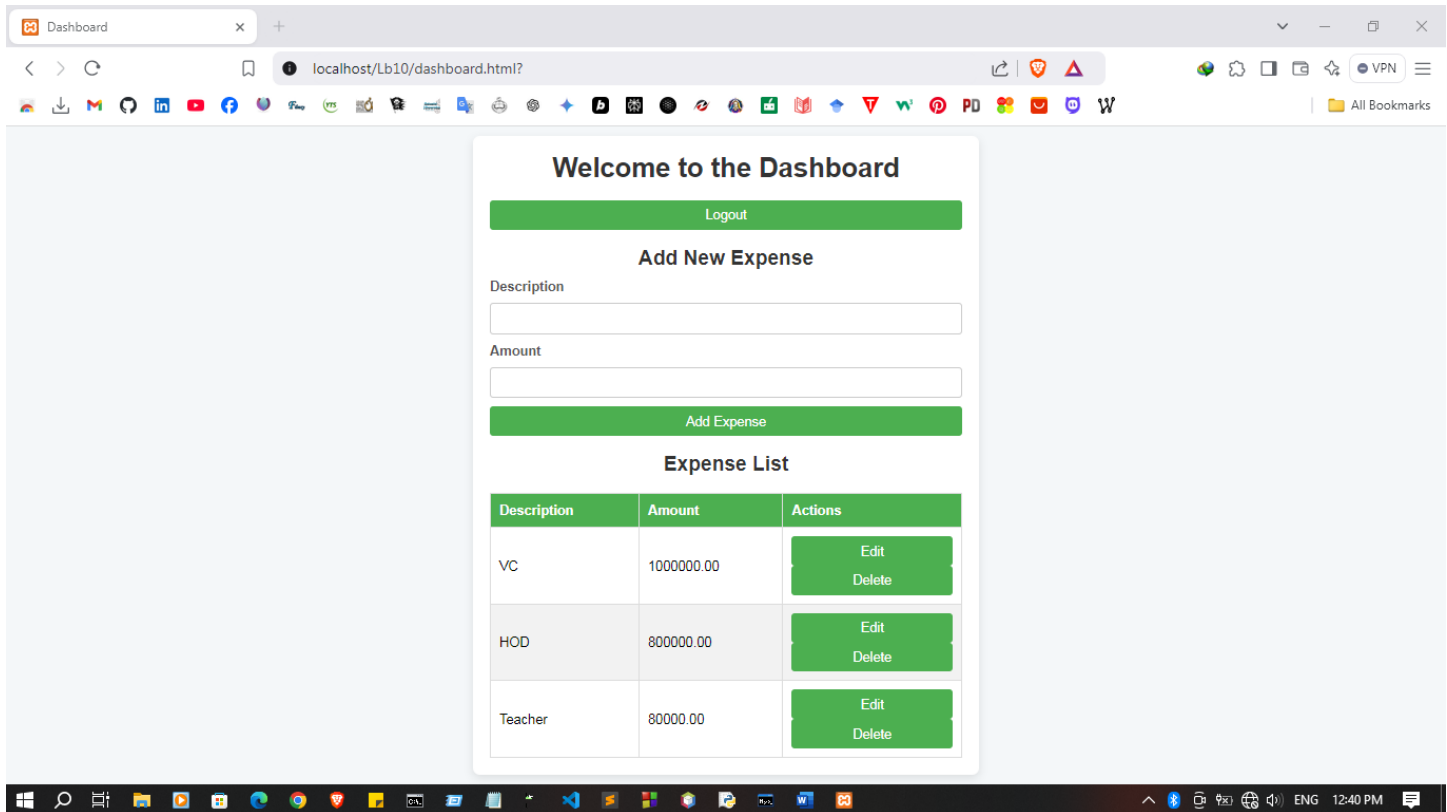
// Login user
async function login() {
    const username = document.getElementById('loginUsername').value.trim();
    const password = document.getElementById('loginPassword').value.trim();

    if (username && password) {
        try {
            const response = await fetch('php/login.php', {
                method: 'POST',
                headers: { 'Content-Type': 'application/json' },
                body: JSON.stringify({ username, password })
            });
            const result = await response.json();
            if (result.message === "Login success") {
                window.location.href = "dashboard.html"; // Redirect to dashboard
            } else {
                alert("Login failed. Check your username and password.");
            }
        } catch (error) {
            console.error('Login error:', error);
        }
    } else {
        alert("Please enter both username and password.");
    }
}
}

```

Output:





Discussion:

- In this lab session on "Web Security in PHP and JavaScript," the focus was on learning and implementing essential security practices to protect web applications against common threats. We began by identifying typical vulnerabilities such as SQL injection, cross-site scripting (XSS), and cross-site request forgery (CSRF), which are prevalent risks in web development. To address these, we explored PHP security techniques, like data validation, prepared statements for database interactions, and CSRF tokens, which help prevent unauthorized access and data tampering. On the JavaScript side, we learned methods to secure the front end, such as input sanitization and proper encoding to mitigate XSS risks. This session reinforced the importance of integrating security into both backend and frontend code to build robust, safe applications that resist attacks and ensure data integrity.